

CanlıFal Test Planı (§89 #23)

Versiyon: 1.0

Tarih: 2026-08-27

Platform: canlifal.com

Envanter: 776 handler / 498 path / 167 kategori / 214 model

1. Genel Bakış

Bu doküman, CanlıFal platformunun tüm backend API'lerini kapsayan test planıdır. Her API kategorisi için fonksiyonel test senaryoları, kenar durumları ve beklenen davranışlar tanımlanmıştır.

1.1 Test Ortamı

Bileşen	Detay
API Base URL	https://canlifal.com/api
Auth yöntemleri	Mobile JWT (authenticateRequest), Web session (getServerSession), RBAC (resolveUser)
Veritabanı	PostgreSQL (paylaşımlı dev/prod)
Realtime	SSE (20 endpoint)
Rate Limiter	In-memory, 30 guardRateLimit noktası + authLimiter + heavyLimiter

1.2 Auth Dağılımı

Auth Tipi	Route Sayısı
Dual auth (mobile + web)	66
Yalnızca mobile JWT	192
Yalnızca web session	112
RBAC (resolveUser)	15
Public (auth yok)	~100 (GET okuma uçları)

2. Test Kategorileri

2.1 Kimlik Doğrulama (Auth) — 10 uç

#	Senaryo	Yöntem	Uç	Beklenen
A1	Geçerli e-posta/ şifre ile mobil giriş	POST	/api/auth/mo- bile-login	200, access- Token + refresh- Token
A2	Yanlış şifre ile mobil giriş	POST	/api/auth/mo- bile-login	401, hata mesajı
A3	Rate limit aşımı (>10 istek/15dk)	POST	/api/auth/mo- bile-login	429, Retry-After header
A4	Geçerli refresh- Token ile token yenileme	POST	/api/auth/mo- bile-refresh	200, yeni token- lar
A5	Süresi dolmuş refreshToken	POST	/api/auth/mo- bile-refresh	401
A6	Yeni kayıt (geçerli veriler)	POST	/api/signup	200/201
A7	Mevcut e-posta ile kayıt	POST	/api/signup	409/400
A8	Şifre sıfırlama talebi (geçerli e- posta)	POST	/api/auth/forgot- password	200
A9	Google OAuth ile mobil giriş	POST	/api/auth/mo- bile-google	200, tokenlar
A10	Apple OAuth ile mobil giriş	POST	/api/auth/mo- bile-apple	200, tokenlar

2.2 Finansal İşlemler — Hediye Gönderme

#	Senaryo	Yöntem	Uç	Beklenen
F1	Geçerli hediye gönderme (yayın)	POST	/api/live/gift/send	200, bakiye düşer
F2	Yetersiz bakiye ile hediye	POST	/api/live/gift/send	400/402, hata
F3	Kendine hediye gönderme	POST	/api/live/gift/send	400, engellenir
F4	Şanslı hediye gönderme	POST	/api/gifts/lucky/send	200, tier + ödül
F5	Rate limit aşımı (>10/dk)	POST	/api/live/gift/send	429
F6	Sohbet odasında hediye	POST	/api/chat/rooms/{id}/gifts	200
F7	Video yayınında hediye	POST	/api/video-streams/{id}/gifts	200
F8	Geçersiz gift-TypeId	POST	/api/live/gift/send	400
F9	quantity > 100 kesilmeli	POST	/api/live/gift/send	200, max 100
F10	Hediye sonrası ledger kaydı oluşur	POST	/api/live/gift/send	LedgerEntry var

2.3 Finansal İşlemler — Bahşış & Üyelik & Çekim

#	Senaryo	Yöntem	Uç	Beklenen
F11	Geçerli bahşış (50-500 arası)	POST	/api/room/{id}/tip	200
F12	Geçersiz bahşış miktarı	POST	/api/room/{id}/tip	400
F13	Idempotent bahşış (aynı idempotency key)	POST	/api/room/{id}/tip	İlk 200, tekrar 409
F14	Üyelik satın alma (jeton)	POST	/api/member-ships/purchase	200
F15	Üyelik satın alma (CFC)	POST	/api/member-ships/purchase	200
F16	Idempotent üyelik	POST	/api/member-ships/purchase	İlk 200, tekrar 409
F17	Para çekme talebi	POST	/api/withdrawals	200
F18	Idempotent çekim	POST	/api/withdrawals	İlk 200, tekrar 409
F19	Ajans çekim onayı	POST	/api/agency/withdrawals	200
F20	Yetkisiz ajans çekim	POST	/api/agency/withdrawals	403

2.4 Mesajlaşma

#	Senaryo	Yöntem	Uç	Beklenen
M1	DM gönderme	POST	/api/messages/{userId}	200
M2	Engellenmiş kullanıcıya mesaj	POST	/api/messages/{userId}	403
M3	Canlı oda mesajı	POST	/api/live/message	200, SSE tetiklenir
M4	Sohbet odası mesajı	POST	/api/chat/rooms/{id}/messages	200
M5	Susturulmuş kullanıcı mesaj gönderme	POST	/api/chat/rooms/{id}/messages	403
M6	Rate limit aşımı (>30/dk)	POST	/api/messages/{userId}	429
M7	Boş mesaj gönderme	POST	/api/messages/{userId}	400

2.5 Yorum Sistemi

#	Senaryo	Yöntem	Uç	Beklenen
C1	Blog yazısına yorum	POST	/api/blog/com-ments	200
C2	Rüya yorumuna yorum	POST	/api/dreams/{slug}/com-ments	200
C3	Video yayınına yorum	POST	/api/video-streams/{id}/comments	200
C4	Sosyal pay-laşıma yorum	POST	/api/social/posts/{id}/comments	200
C5	Kısa videoya yorum	POST	/api/short-videos/{id}/comments	200
C6	500+ karakter yorum	POST	/api/social/posts/{id}/comments	400
C7	Rate limit aşımı (>20/dk)	POST	/api/blog/com-ments	429
C8	Auth olmadan yorum	POST	/api/blog/com-ments	401

2.6 Canlı Yayın (Video Streams)

#	Senaryo	Yöntem	Uç	Beklenen
VS1	Yayın oluşturma	POST	/api/video-streams	200, stream objesi
VS2	Rate limit aşımı (>5/dk)	POST	/api/video-streams	429
VS3	Yayına katılma	POST	/api/video-streams/{id}/join	200
VS4	Yayından ayrılma	POST	/api/video-streams/{id}/leave	200
VS5	Yayın sonlandırma (sahip)	PATCH	/api/video-streams/{id}	200, status=ended
VS6	Yayın sonlandırma (sahip değil)	PATCH	/api/video-streams/{id}	403
VS7	SSE stream bağlantısı	GET	/api/video-streams/{id}/stream	200, text/event-stream
VS8	PK battle başlatma	POST	/api/video-streams/pk	200
VS9	Moderatör atama	POST	/api/video-streams/{id}/moderators	200
VS10	Kullanıcı banlama	POST	/api/video-streams/{id}/ban	200

2.7 Sohbet Odaları (Voice Rooms)

#	Senaryo	Yöntem	Uç	Beklenen
VR1	Oda oluşturma	POST	/api/chat/rooms/ create	200
VR2	Rate limit aşımı (>5/dk)	POST	/api/chat/rooms/ create	429
VR3	Odaya katılma (presence)	POST	/api/chat/rooms/ {id}/presence	200
VR4	Konuşma talebi	POST	/api/chat/rooms/ {id}/speak-re- quest	200
VR5	Koltuk yönetimi	PATCH	/api/chat/rooms/ {id}/seats	200
VR6	PK battle	POST	/api/chat/rooms/ {id}/pk	200
VR7	DJ müzik oyn- atma	POST	/api/chat/rooms/ {id}/dj	200
VR8	SSE stream	GET	/api/chat/rooms/ {id}/stream	200, text/event- stream

2.8 Fal Sistemi

#	Senaryo	Yöntem	Uç	Beklenen
FT1	Tarot falı (SSE stream)	POST	/api/fortunes/tarot-fali	200, SSE
FT2	Kahve falı (görüntü analizi)	POST	/api/fortunes/kahve-fali-image	200, SSE
FT3	Burç yorumu	POST	/api/fortunes/burc-yorumu	200, SSE
FT4	Rüya yorumu	POST	/api/fortunes/ruya-yorumu	200, SSE
FT5	Aura analizi	POST	/api/fortunes/aura-analizi	200, SSE
FT6	Aşk uyumu	POST	/api/fortunes/ask-uyumu	200, SSE
FT7	Numeroloji	POST	/api/fortunes/numeroloji	200, SSE
FT8	Evet/Hayır	POST	/api/fortunes/evet-hayir	200, SSE
FT9	Canlı falcı oturumu başlatma	POST	/api/fortune-tellers/{id}/session	200
FT10	Oturum SSE stream	GET	/api/room/{id}/stream	200, text/event-stream

2.9 Kullanıcı & Profil

#	Senaryo	Yöntem	Uç	Beklenen
U1	Profil bilgisi alma	GET	/api/user/profile	200
U2	Profil güncelleme	PATCH	/api/user/profile	200
U3	Kullanıcı takip etme	POST	/api/user/{id}/follow	200
U4	Kullanıcı engelleme	POST	/api/user/block	200
U5	Kullanıcı şikayet etme	POST	/api/user/report	200
U6	Rate limit aşımı (>5/dk)	POST	/api/user/report	429
U7	/api/me bilgileri	GET	/api/me	200

2.10 Admin Paneli

#	Senaryo	Yöntem	Uç	Beklenen
AD1	Admin olmayan kullanıcı erişimi	GET	/api/admin/*	401/403
AD2	Kredi ekleme	POST	/api/admin/credits	200
AD3	Feature flag toggle	PATCH	/api/admin/feature-flags/{id}	200
AD4	Audit log listesi	GET	/api/admin/audit	200, cursor pagination
AD5	Ledger listesi	GET	/api/admin/ledger	200, cursor pagination
AD6	Risk event listesi	GET	/api/admin/risk-events	200, pagination
AD7	Risk event inceleme	PATCH	/api/admin/risk-events/{id}	200, audit log
AD8	Destek talebi listesi	GET	/api/admin/support	200
AD9	Doğrulama onay/ret	PATCH	/api/admin/verification	200, audit log
AD10	Efekt kuralı CRUD	POST/PATCH/DELETE	/api/admin/effect-rules	200

2.11 Destek & Doğrulama & Takımlar

#	Senaryo	Yöntem	Uç	Beklenen
S1	Destek talebi oluşturma	POST	/api/support/tickets	200
S2	Talep mesajı ekleme	POST	/api/support/tickets/{id}/messages	200
S3	Doğrulama talebi	POST	/api/verification	200
S4	Tekrarlanan doğrulama talebi	POST	/api/verification	409
S5	Takım oluşturma	POST	/api/teams	200
S6	Takım güncelleme	PATCH	/api/teams/{id}	200

2.12 Kısa Videolar & Hikayeler & Sosyal

#	Senaryo	Yöntem	Uç	Beklenen
SV1	Video yükleme	POST	/api/short-videos/upload	200
SV2	Rate limit aşımı (>5/dk)	POST	/api/short-videos/upload	429
SV3	Video beğenme	POST	/api/short-videos/{id}/like	200
SV4	Hikaye oluşturma	POST	/api/stories	200
SV5	Sosyal paylaşım oluşturma	POST	/api/social/posts	200
SV6	Rate limit aşımı (>10/dk)	POST	/api/social/posts	429

2.13 Derin Bağlantı & Bootstrap & Config

#	Senaryo	Yöntem	Uç	Beklenen
DL1	URL ile derin bağlantı çözme	GET	/api/v1/deeplink/ resolve?url=...	200, DeepLink
DL2	type+value ile bağlantı üretme	GET	/api/v1/deeplink/ resolve?type=... &value=...	200
DL3	Geçersiz URL çözme	GET	/api/v1/deeplink/ resolve?url=xxx	404
DL4	Bootstrap (tüm config)	GET	/api/v1/boot- strap	200, flags+configs+s ettings
DL5	Config endpoint	GET	/api/config	200
DL6	Efekt çözüm- leme	GET	/api/effects/re- solve	200, efekt listesi

3. Çapraz Kesişim Test Matrisi

3.1 Güvenlik Testleri

#	Test	Beklenen
SEC1	Auth token olmadan korumalı uca erişim	401
SEC2	Süresi dolmuş JWT ile erişim	401
SEC3	Admin uçlarına normal kullanıcı erişimi	401/403
SEC4	Başka kullanıcının verisini okuma/yazma	403 veya boş yanıt
SEC5	SQL injection denemesi (parametrelerde)	400 veya Prisma hatası, veri sızıntısı yok
SEC6	XSS payload'ı (content alanlarında)	Sanitize edilmiş veya encode edilmiş

3.2 Rate Limit Testleri

Scope	Limit	Pencere	Test uçları
auth	10	15 dk	mobile-login, signup, forgot-password
gift_send	10	1 dk	live/gift/send, chat/rooms/gifts, video-streams/gifts
lucky_gift	10	1 dk	gifts/lucky/send
chat_message	30	1 dk	messages/{id}, live/message, chat/rooms/messages
comment	20	1 dk	blog/comments, dreams/comments, vb.
content_create	10	1 dk	social/posts, stories
withdrawal	5	1 dk	withdrawals, agency/withdrawals
tip	10	1 dk	room/{id}/tip
membership	5	1 dk	memberships/purchase
report	5	1 dk	user/report, support/tickets, verification
upload	5	1 dk	short-videos/upload
stream_create	5	1 dk	video-streams
room_create	5	1 dk	chat/rooms/create
pk_create	10	1 dk	live/pk, video-streams/pk, chat/rooms/pk
payment	10	1 dk	payments/requests
agency_action	5	1 dk	agency/join, agency/apply

3.3 Idempotency Testleri

Uç	Scope	Test
POST /api/withdrawals	withdrawal	Aynı key ile 2. istek → 409
POST /api/payments/requests	payment_request	Aynı key ile 2. istek → 409
POST /api/room/{id}/tip	tip	Aynı key ile 2. istek → 409
POST /api/memberships/purchase	membership_purchase	Aynı key ile 2. istek → 409

3.4 SSE (Server-Sent Events) Testleri

#	Test	Uç	Beklenen
SSE1	Bağlantı açma	GET /api/video-streams/{id}/stream	200, Content-Type: text/event-stream
SSE2	Event alma (mesaj gönderildiğinde)	—	data: JSON event
SSE3	Bağlantı kapandığında temizlik	—	Listener kaldırılır
SSE4	Auth olmadan SSE	—	401 veya boş stream

4. Test Araçları Önerileri

Araç	Kullanım
Postman / Newman	API fonksiyonel testleri (koleksiyon: backend-docs/postman_collection.json)
k6 / Artillery	Yük testleri (bkz. CANLI-FAL_LOAD_TEST_PLAN.md)
curl / httpie	Hızlı smoke test
Jest + Supertest	Unit/integration test (opsiyonel)

5. Öncelik Sıralaması

Öncelik	Kategori	Neden
P0 (Kritik)	Auth, Finansal, Rate Limit	Para ve güvenlik
P1 (Yüksek)	SSE, Mesajlaşma, Canlı Yayın	Kullanıcı deneyimi
P2 (Orta)	Yorum, Sosyal, Admin	Fonksiyonellik
P3 (Düşük)	Config, Deep Link, Bootstrap	Yardımcı

6. Regresyon Test Stratejisi

1. **Her deployment öncesi:** P0 senaryolarının tamamı çalıştırılmalı
2. **Haftalık:** P0 + P1 senaryoları
3. **Aylık:** Tam test suite (P0-P3)
4. **Her faz sonrası:** Değişen kategorinin tüm senaryoları + P0